

Risk_ID	Asset
---------	-------

GOVERNANCE (GOV)

GOV-01	Cyber Governance Program
GOV-02	Critical Vendor Oversight
GOV-03	IT Integration (M&A)
GOV-04	Enterprise BCDR

COMPLIANCE / PRIVACY (CMP)

CMP-01	HIPAA Program
CMP-02	Cloud EHR Vendor
CMP-03	Patient Mobile App
CMP-04	Credentialing System
CMP-05	Research Data

OPERATIONS / CLINICAL CONTINUITY (OPS)

OPS-01	Cloud EHR
OPS-02	Claims/Clearinghouse
OPS-03	Imaging/PACS
OPS-04	Pharmacy Systems
OPS-05	Procurement/Supply Chain

SECURITY (SEC)

SEC-01	Medical Devices
SEC-02	Cloud IAM
SEC-03	Clearinghouse Vendor
SEC-04	Email/Collaboration
SEC-05	AI/External Tools

Scenario	Category	Likelihood	Impact
----------	----------	------------	--------

Inadequate cyber-clinical oversight across hospitals	GOV	Medium	High
Weak assurance for cloud EHR & clearinghouse vendors	GOV	High	Critical
Fragmented systems after regional acquisition	GOV	Low	Medium
No unified downtime playbook across sites	GOV	Medium	High

HIPAA SRA gaps for multi-cloud footprint	CMP	Medium	High
Multi-state PHI breach (vendor compromise)	CMP	Medium	Critical
Unauthorized tracking/analytics tech	CMP	Medium	Medium
PII exposure from legacy systems	CMP	Low	High
Noncompliant genomic dataset storage	CMP	Low	High

Multi-day outage → clinical diversion	OPS	Medium	Critical
Vendor outage halts claims	OPS	Medium	High
PACS inaccessible during network events	OPS	Low	High
e-Prescribing/fulfillment outage	OPS	Low	Medium
Medical supply ordering portal down	OPS	Low	Medium

Ransomware via vulnerable devices	SEC	Medium	High
Privileged identity compromise	SEC	Medium	Critical
Ransomware & PHI exposure	SEC	Medium	Critical
Phishing → internal compromise	SEC	High	Medium
Data leakage via unapproved AI apps	SEC	Low	Medium

Status	Lambda_Min	Lambda_Mode	Lambda_Max	Loss_Min	Loss_Mode	Loss_Max
--------	------------	-------------	------------	----------	-----------	----------

Open	0.2	0.4	0.7	1,000,000	3,000,000	7,000,000
Open	0.5	0.8	1	2,000,000	6,000,000	15,000,000
Mitigated	0.05	0.1	0.2	200,000	400,000	1,000,000
Open	0.2	0.3	0.5	1,500,000	3,000,000	6,000,000

Open	0.3	0.5	0.8	1,500,000	4,000,000	9,000,000
Open	0.15	0.25	0.4	5,000,000	15,000,000	50,000,000
Open	0.2	0.4	0.7	750,000	2,000,000	6,000,000
Mitigated	0.05	0.1	0.2	250,000	700,000	2,000,000
Open	0.1	0.2	0.3	1,000,000	3,500,000	8,000,000

Open	0.2	0.35	0.6	4,000,000	12,000,000	30,000,000
Open	0.25	0.5	0.9	3,000,000	8,000,000	25,000,000
Mitigated	0.1	0.2	0.3	500,000	2,000,000	4,000,000
Mitigated	0.05	0.1	0.2	250,000	600,000	1,200,000
Accepted	0.05	0.1	0.15	100,000	250,000	800,000

Open	0.2	0.4	0.7	2,000,000	7,000,000	20,000,000
Open	0.15	0.3	0.5	4,000,000	12,000,000	40,000,000
Open	0.2	0.35	0.6	5,000,000	14,000,000	45,000,000
Mitigated	0.4	0.6	0.9	500,000	1,200,000	3,000,000
Open	0.05	0.1	0.2	300,000	900,000	2,500,000

Owner	Notes
-------	-------

Chief Risk Officer	Board lacks integrated cyber/patient-safety KPIs
VP Vendor Risk	Vendor tiering incomplete
CIO	Integration plan underway
BCDR Director	Sites rely on local downtime plans

Chief Compliance Officer	SRA incomplete for SaaS & EHR cloud
CISO	Mirrors Change Healthcare-scale events
Privacy Officer	Pixel investigation underway
Compliance Officer	Legacy data migration in progress
Director Research IT	Shadow IT storage detected

CMIO	Downtime → paper workflows
VP Revenue Cycle	Revenue backlog risk
Director Radiology IT	Segmentation implemented
Pharmacy Director	Fallback in place
Supply Chain Manager	Low impact

Director Biomed Security	Unsupported OS devices
Director IAM	PAM partially implemented
CISO	Mirrors Change Healthcare
Security Awareness Lead	MFA strong
Director Data Gov	AI usage unregulated

Risk Description	Regulatory Impact	Risk Rating
------------------	-------------------	-------------

Insufficient cyber-clinical governance elevates systemic risk	Indirect (HIPAA/CMS)	High
Vendor misalignment causes systemic PHI & downtime risk	HIPAA/HITECH	Critical
Fragmented EHR & IAM increases operational risk	HIPAA	Medium
Lack of unified downtime approach impacts continuity	CMS, HIPAA	High

SRA gaps expose PHI & OCR penalties	HIPAA/HITECH	High
PHI breach triggers litigation & multi-state notifications	HIPAA, State privacy	Critical
Tracking tech violations → regulatory scrutiny	HIPAA/FTC	High
Provider PII exposure during transition	State privacy	Medium
Sensitive research data outside governance	HIPAA, NIH	High

Large-scale EHR outage halts operations	CMS, HIPAA	Critical
Claims disruption impacts cash flow	None	High
Image access disruption impacts care	Patient safety	Medium
E-prescription flow disruption	None	Medium
Disrupted purchasing workflow	None	Low

Ransomware propagation from unmanaged devices	HIPAA	High
Cloud admin compromise → systemic risk	HIPAA/HITECH	Critical
PHI exposure + claims outage	HIPAA/HITECH	Critical
Credential compromise risk	HIPAA	Medium
PHI leakage to AI providers	HIPAA/FTC	Medium

Mitigation/Control

Establish board-level cyber risk subcommittee
Enforce RPO/RTO SLAs; deep vendor assessments
Standardized integration playbooks
Centralize & standardize downtime procedures

Full enterprise SRA + third-party inclusion
Vendor encryption controls; independent audits
Remove trackers; update DPAs
Migration governance controls
Move to secure enclave

Failover validation + downtime drills
Redundant clearinghouse
Segmentation + cached viewers
Redundant routing + fax fallback
Accepted by leadership

Segmentation + virtual patching
JIT access + PAM + MFA
Vendor segmentation + failover
Awareness + advanced filtering
AI governance policy